	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Vamos a usar nuestras máquinas de Kali Linux y Metasploitable para realizar estos ejercicios.

En Metasploitable 2 iniciamos sesión como se nos indica **msfadmin / msfadmin**

<u>Escaneo básico de red:</u>

Ahora en Kali Linux usamos el comando **map -sn [IP de la subred]**

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.56.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-31 14:17 EDT
Nmap scan report for 192.168.56.4
Host is up (0.00028s latency).
Nmap done: 1 IP address (1 host up) scanned in 13.01 seconds
```

Este comando permite ver qué hosts están activos en la red.

<u>Escaneo de puertos abiertos:</u>

Vamos a usar el comando **nmap -sS [IP de Metasploitable]** para realizar un escaneo de los puertos

```
kali@kali: ~
File  Actions  Edit  View  Help
QUITTING!

┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS 192.168.56.4
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-31 13:47 EDT
Nmap scan report for 192.168.56.4
Host is up (0.000075s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:6A:26:D7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.33 seconds
```

Este comando muestra los puertos TCP abiertos en el equipo de destino.

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Detección de versiones de servicios:

Para obtener información sobre las versiones de los servicios en ejecución usamos el comando **nmap -sV [IP de Metasploitable]**

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-31 13:49 EDT
Nmap scan report for 192.168.56.4
Host is up (0.00038s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.43 seconds
```

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Escaneo de sistema operativo:

Para detectar el sistema operativo que ejecuta el equipo de destino usamos el comando **nmap -O [IP de Metasploitable]**

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -O 192.168.56.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-31 13:50 EDT
Nmap scan report for 192.168.56.4
Host is up (0.00025s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:6A:26:D7 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.o
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.54 seconds
```

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Escaneo:

Ejecuta el siguiente comando y explica para qué se usa -sC y que salidas muestra. (Hay que usar **sudo).**

-O Muestra el sistema operativo

-sV Muestras las versiones de los servicios

-sC Muestra los nombres de los servicios

```
kali@kali: ~
File  Actions  Edit  View  Help
└─$ sudo nmap -O -sV -sC 192.168.56.4
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-04 11:45 EST
Nmap scan report for 192.168.56.4
Host is up (0.00023s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.3
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
```

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

<u>Escaneo puerto 21:</u>

Escanea con las opciones -sV y -sC UNICAMENTE el puerto 21(FTP) de Metasploitable.

Usamos el comando **nmap -sV -sC -p 21 192.168.56.4**

¿Puedes ver si tenemos el acceso anónimo activado? **SÍ. (ftp-anon: Anonymous FTP login allowed (FTP code 230))**

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC -p 21 192.168.56.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-31 14:01 EDT
Nmap scan report for 192.168.56.4
Host is up (0.00033s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.3
```

Entra como anónimo en el ftp de la máquina.

Para ello usamos **ftp 192.168.56.4** y una vez dentro metemos el usuario **anonymous** y pulsamos intro para no meter contraseña.

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.56.4
Connected to 192.168.56.4.
220 (vsFTPd 2.3.4)
Name (192.168.56.4:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||34316|).
150 Here comes the directory listing.
226 Directory send OK.
ftp>
```

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

<u>Escaneo de otro puerto:</u>
Elige otro de los puertos/servicios de la máquina Metasploitable y busca que vulnerabilidades puedes encontrar para dicho servicio y versión instalada. Pon las fuentes de donde obtienes la información.

Voy a usar el puerto 445 del servicio de **samba**

```
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
```

Para ello voy a usar el comando **nmap -sV -sC -p 445 192.168.56.4**

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -O -sV -sC -p 445 192.168.56.4
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-04 11:58 EST
Nmap scan report for 192.168.56.4
Host is up (0.00026s latency).

PORT    STATE SERVICE     VERSION
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 08:00:27:6A:26:D7 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2024-11-04T12:58:40-05:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 3h30m00s, deviation: 3h32m07s, median: 1h00m00s
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC:
 <unknown> (unknown)

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.26 seconds
```

	Curso:	**2024-2025**	*Ciclo:*	**SISTEMAS MICROINFORMÁTICOS Y REDES**
	Fecha:	**4/11/2024**	*Módulo:*	**Seguridad Informática**
	Tipo:	**PRÁCTICA**	*Profesor:*	**Juan Fco. Carrillo Torralbo.**
	Título:	**Pentesting 2. Análisis información pública. Nmap**		

Apellidos:	***Martínez Saura***	*Nota:*	
Nombre:	*Ángel David*		

Vulnerabilidad de SAMBA

Microsoft ha publicado un boletín de seguridad informando sobre una vulnerabilidad en el protocolo Microsoft Server Message Block 3.1.1 «SMBv3» que podría permitir a un atacante ejecutar código malicioso, tanto en los dispositivos cliente, como en el servidor.

SMB puede permitir a un atacante remoto obtener información confidencial de los sistemas afectados. El puerto 445 ya ha sido utilizado por varios tipos de ataques, incluyendo los gusanos Sasser y Nimda, para esto dicho puerto necesita estar abierto en entornos Windows.

Para minimizar el riesgo, desde Microsoft también recomiendan **bloquear mediante el *firewall* de la empresa las conexiones TCP al puerto 445 que provengan de Internet,** ya que este es el puerto utilizado por SMB para comunicarse. De esta manera, se evita que los ciberdelincuentes sean capaces de aprovechar la vulnerabilidad.

Bibliografía:
https://www.ecucert.gob.ec/wp-content/uploads/2021/07/Ficha-Tecnica-Accesible-SMB.pdf
https://www.incibe.es/empresas/avisos/detectada-vulnerabilidad-afecta-al-protocolo-smb-windows